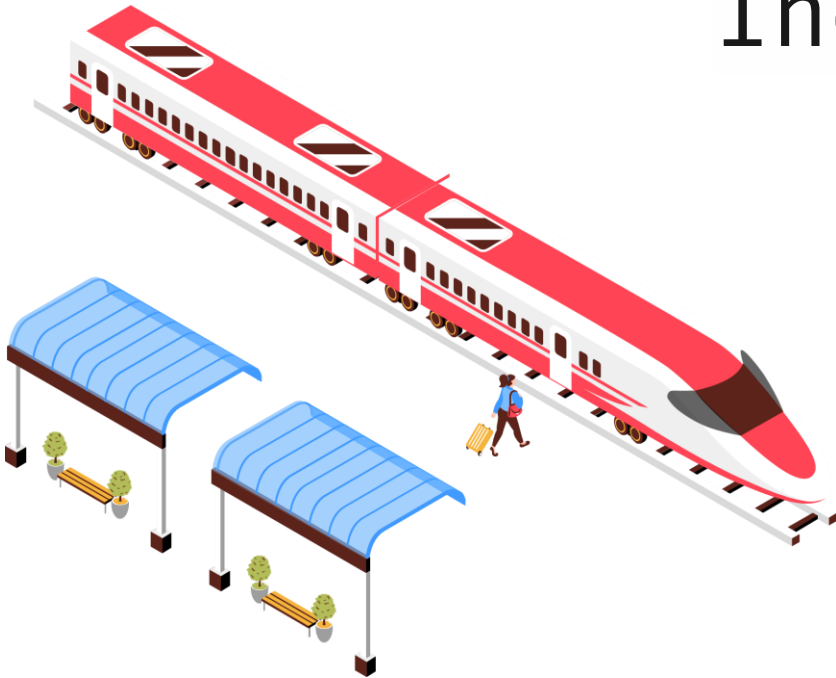
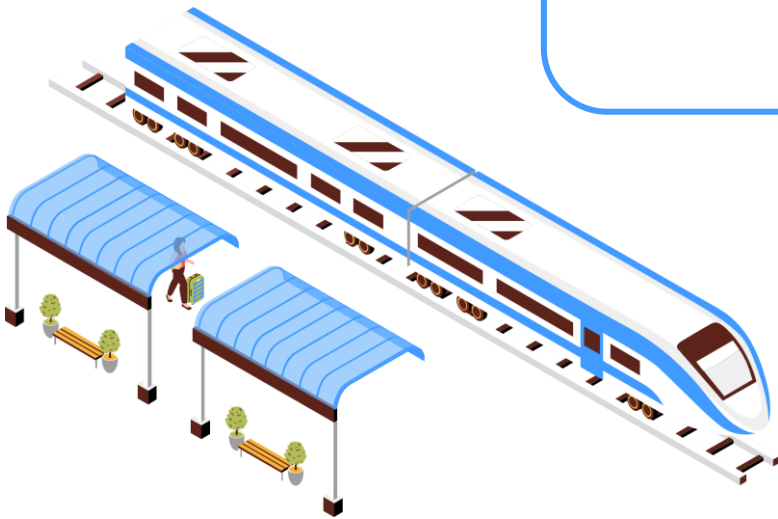


Cyber-security in Industrial Control Systems

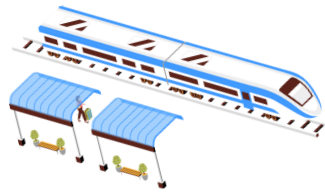


**Kawtar Zerhouni, Maîtresse de conférences
UTER MID@S - ECC**

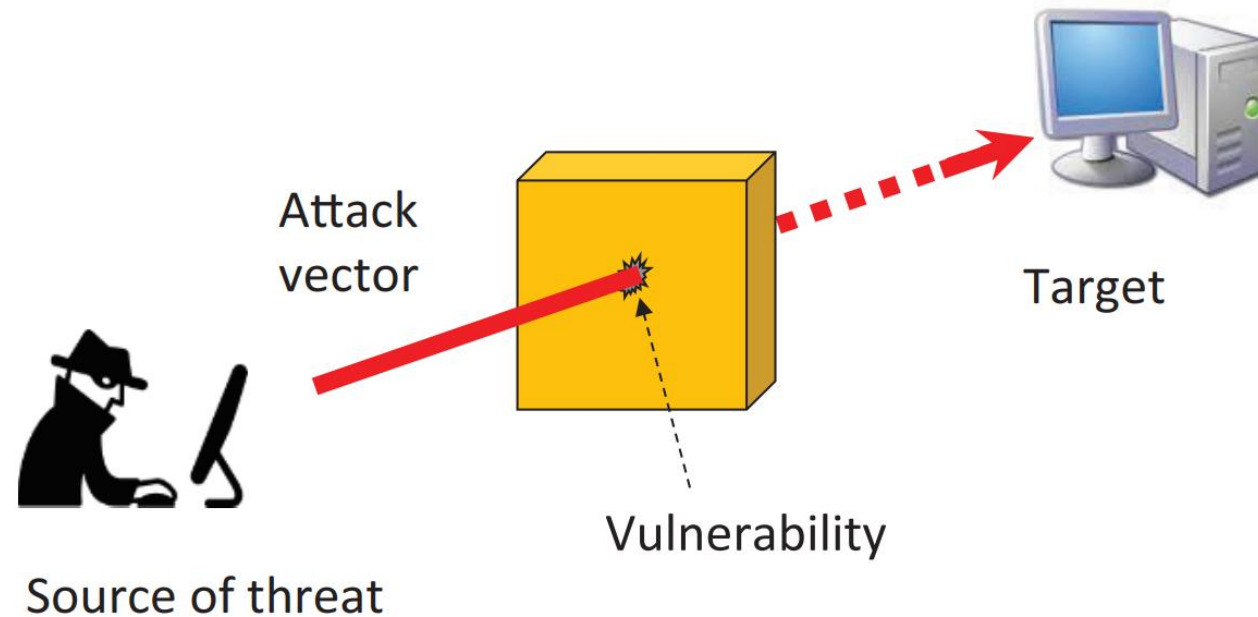
Threats and Attacks to ICS



Threats and Attacks to ICS



In general, an ICS is subject to threats, generated by ***sources of threats***. The path or means used to access the target system is called the ***“attack vector”***.



The success of an attack on a computer system depends on at least one ***vulnerability*** being exploited; it can be technical, human or organizational.



Threats and Attacks to ICS



Source of threat

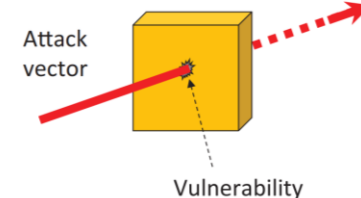
sources of threats:

- Various types of threat sources exist.
- An initial classification is provided by the NIST guide SP800-82.
- It shows all sources capable of causing damage to an information system

Type of source	Description
Malicious human action	Entities such as individuals, groups, organizations, or even states aim to exploit the organization's reliance on information resources
Human Error	Accidental actions performed by individuals while carrying out their routine responsibilities.
Technical system	Equipment failures, absence of environmental control, software design or implementation flaws, and resource depletion.
Natural and anthropogenic environment	Natural disasters and failures of critical infrastructure, which the organization relies on but are beyond its control.



Threats and Attacks to ICS



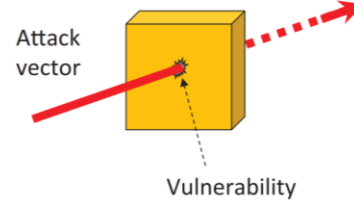
Attack vectors:

- Means used to carry out an attack.
- The selection of an attack vector is determined by exploiting a vulnerability within the system.

Category	Vectors of attack
Physical access	Removal media on USB port or other - USB keyboard socket (keylogger) Serial and other ports (SATA, Display port, HDMI, etc.) - RJ45 ports Direct access via keyboard/mouse - Flash memory cards
Network	Internet connections - Cloud connections Split tunneling (simultaneous access to protected resources via VPN) Industrial or IoT wireless networks (Hart, Zigbee, etc.)
People	Social engineering Corrupted client email and attachments Internet browser



Attack types : Malwares

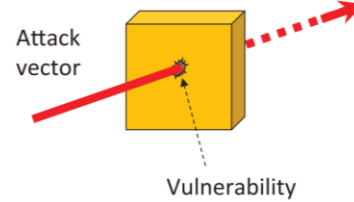


- Computers, network equipment, ICS components, and IoT devices are programmable devices with memory areas containing both data and programs.
- Some zones within these devices are immutable, while others are modifiable but retain data during power interruptions, and some are cleared upon device shutdown.
- Upon startup, the system executes a predefined and unmodifiable program, initiating a start program at a specific address.

→ Attackers may attempt to modify memory areas, insert malicious code into the boot address, or execute this code by altering the stack.



Attack types : Malwares



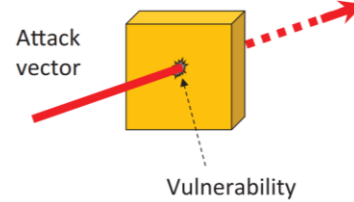
- Systems connected to a Transmission Control Protocol (TCP)/Internet Protocol (IP) network function by monitoring the network through logical ports, commonly referred to as "open ports".
- Each port is associated with default software; for instance, Telnet listens on port 23 and Modbus uses port 502.
- Attackers can exploit vulnerabilities in protocols and applications using these ports to alter data, acquire passwords, or execute code on workstations or equipment.

Keep in mind: ICS Equipment such as PLCs are particular computer systems, which can therefore be subject to the same attacks.

These various possibilities are exploited by malware.



Attack types : Malwares



These various possibilities are exploited by malware.

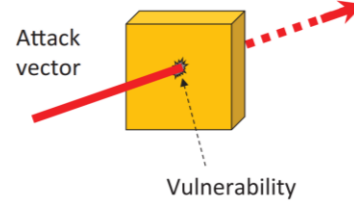
Malware, short for **malicious software**, refers to **any type of software intentionally** designed to cause harm to a computer system, network, or device.

Virus/worms

- The main difference between a worm and a virus lies in how they spread.
- A virus typically **requires user interaction to propagate**, often by attaching itself to executable files or documents, and relies on users executing those files.
- In contrast, a worm is a **standalone program** that can spread independently across networks without user intervention, exploiting vulnerabilities in network services or operating systems to replicate itself automatically.
- While both can cause damage by infecting systems, worms are usually more disruptive due to their ability to spread rapidly and autonomously.



Attack types : Malwares



Trojan horse

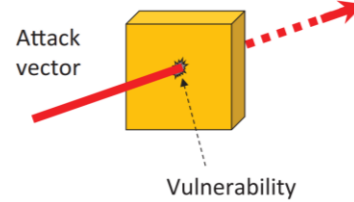
- A Trojan horse is software that appears to perform a legitimate function while secretly embedding malicious software.
- This analogy draws from the Greek myth of the giant wooden horse concealing Greek warriors.
- Similarly, in computing, a Trojan horse deceives users into installing hidden malware on their machines, enabling clandestine actions such as spying and transmitting user information to unauthorized servers.

Logical bomb

- A logical bomb is a type of malware that covertly installs itself, often within a Trojan horse, and activates predetermined actions at a specified date set by hackers.



Attack types : Malwares



Rootkit

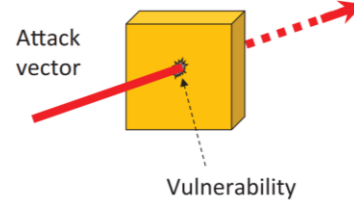
- A rootkit is a form of malicious software that surreptitiously installs itself, **aiming to grant unauthorized privileged user access to an attacker**.
- This access grants the attacker nearly all privileges, enabling them to execute a wide range of actions on an operating system.

Spyware

- Spyware is software designed to clandestinely **monitor users and document their activities**, typically installed without their awareness.
- Its functionalities encompass recording keystrokes (known as keylogging) during website visits, capturing audio, images, or other data without user consent.



Attack types : Attacks on equipment and applications



Buffer overflow

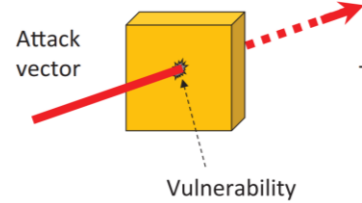
- A buffer overflow attack occurs when an attempt is made to **store more data** in a memory area than it can accommodate.
- This action can lead to corruption of other variables, system crashes, or, if the overflow occurs in a strategically positioned zone, manipulation of the subroutine call stack, potentially resulting in the execution of malicious code.

Brute force attack

- A brute force attack is a method employed by certain software to decipher encrypted data, such as passwords or encryption keys, through a trial-and-error process.
- While brute force is regarded as a foolproof technique, it is time-consuming.
- In practice, software conducting such attacks often combines brute force with a dictionary approach, testing common passwords and dictionary words first, followed by variations, before exhaustively testing all combinations.



Attack types : Attacks on equipment and applications

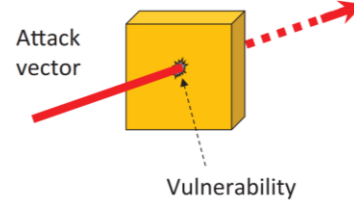


Attack via a zero day flaw

- A “zero day” attack is an attack that exploits vulnerabilities that **have not been fixed or made public**. Often, this type of attack includes attacks targeting vulnerabilities known to the public but not yet fixed.

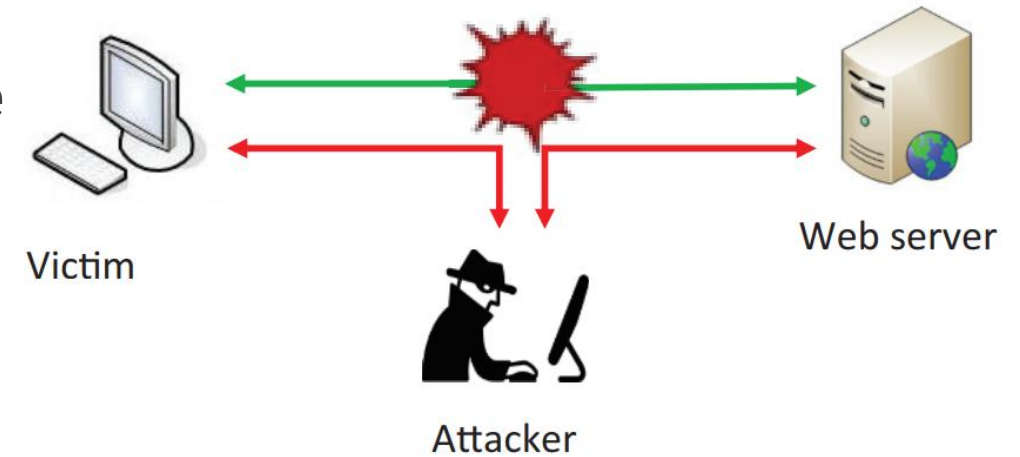


Attack types : Network attacks



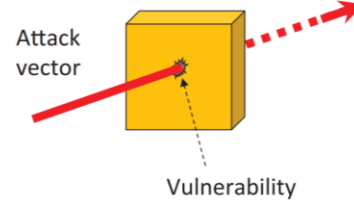
Man In the Middle

- The concept behind MiM involves **intercepting communications between two parties** via a relay, without the knowledge of the communicating parties
- This can be achieved through various technique
- ARP cache poisoning
- DNS spoofing
- ICMP redirection



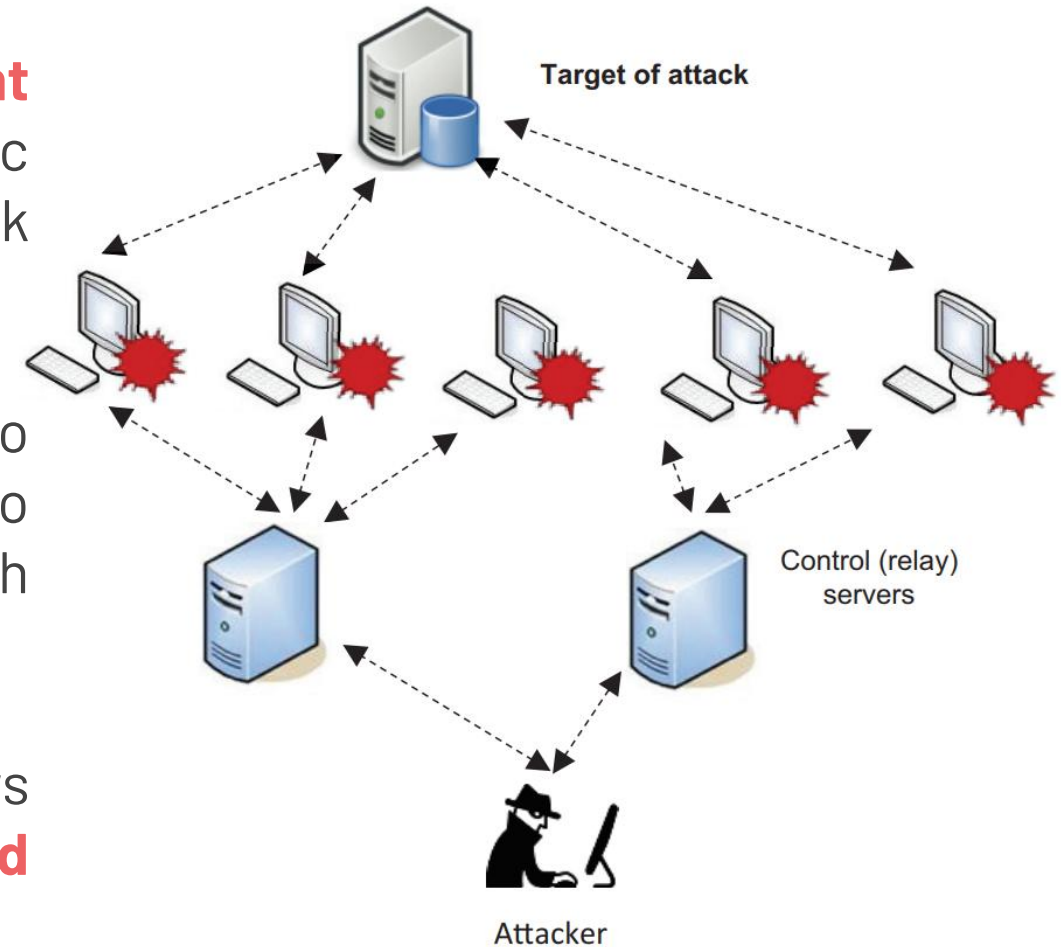


Attack types : Network attacks



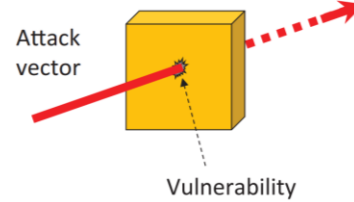
Denial of Service Dos

- In a DoS attack, the attacker tries to **prevent authorized users from accessing** either specific information or the computer system or the network itself.
- This can be accomplished by causing the system to shut down unexpectedly (e.g. by buffer overflow) to cause a cessation of service or by flooding it with requests (e.g. with a botnet).
- A DoS attack conducted by a network of computers or connected objects is called a **DDoS (Distributed DoS) attack**.



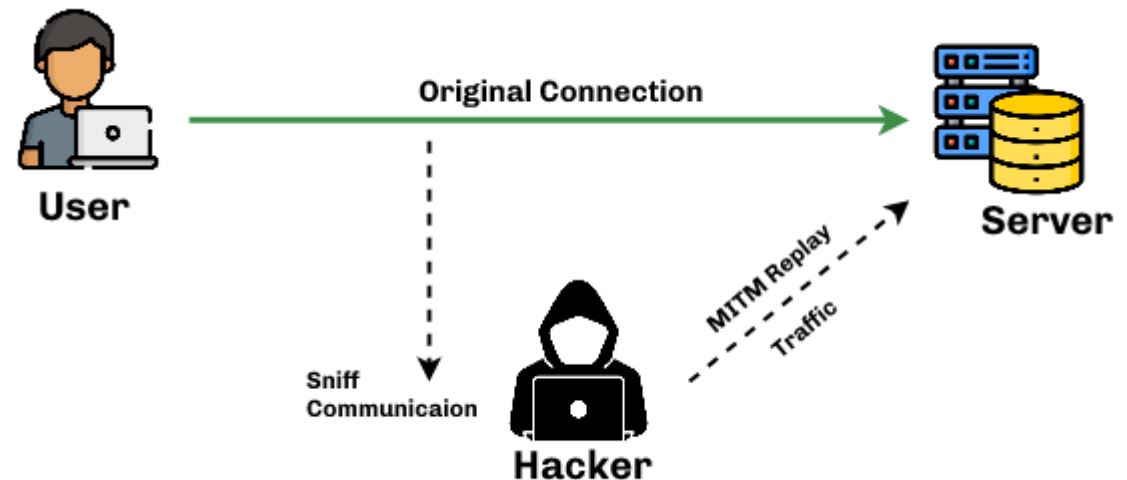


Attack types : Network attacks



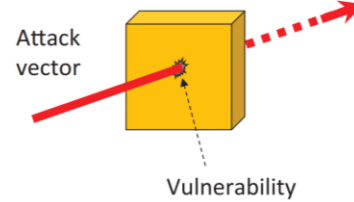
Replay attack

- A replay attack is an attack that consists of **intercepting packets from the network**, possibly by a MiM mechanism, and then **reusing them** to forward them to the recipient. It is not necessary to understand or decipher them.
- An attack of this type is possible against certain types of vulnerable PLCs: an attacker with access to the OT network can steal session numbers and add arbitrary commands to stop or restart the PLC

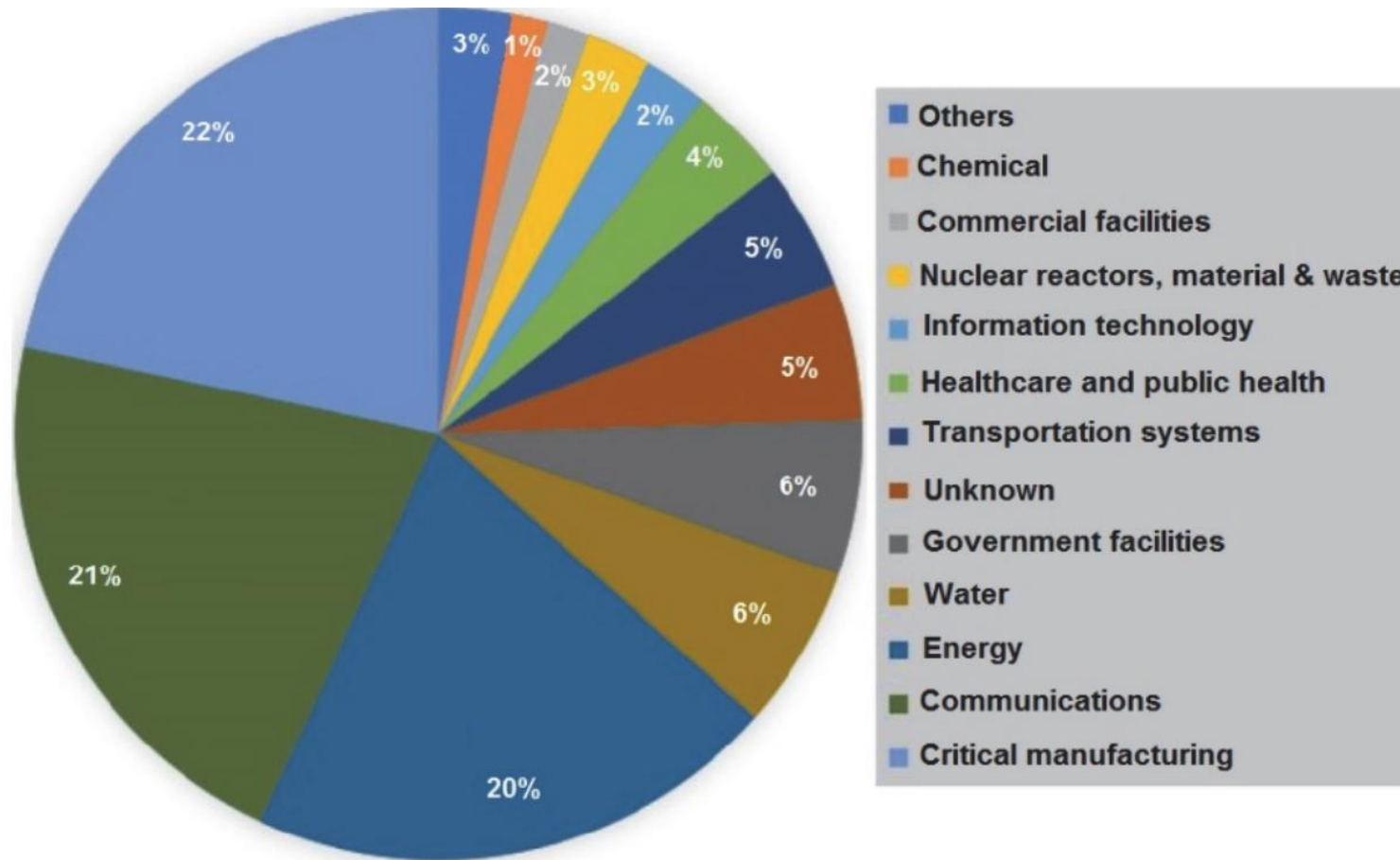




Attack types : some real life examples

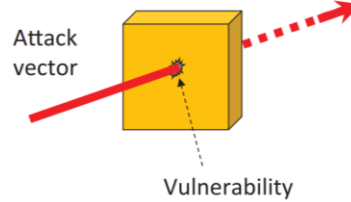


- The first known attack on an ICS was in **1982** on a gas pipeline in Russia.
- A **Trojan horse** introduced into a **SCADA system** caused the pipeline to explode.





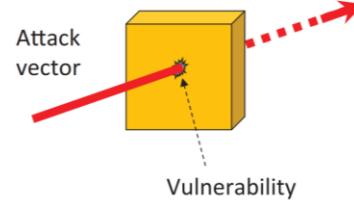
Attack types : some real life examples



- In 2011, Stuxnet left a significant impact on the cybersecurity landscape of industrial systems, shedding light on the susceptibility of SCADA systems.
- As per undisclosed reports, Stuxnet emerged as a **computer worm** crafted to impede Iran's nuclear program.
- Specifically aimed at PLCs used in centrifuges for uranium enrichment, Stuxnet posed a potential threat to dismantling **20% of production capacity**.



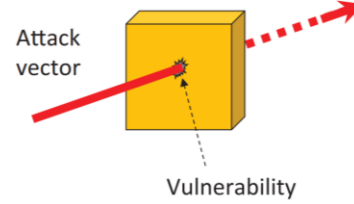
Attack types : some real life examples



- In 2016, researchers demonstrated a notable IoT attack targeting *Philips Hue lamps*.
- These researchers successfully gained control over a network of Philips Hue lamps, which are connected via **Zigbee networks** and can be controlled using a remote to adjust light intensity and color.
- The attack revealed a significant **security flaw** wherein **all connected bulbs used the same encryption keys**, enabling malware-infected bulbs to easily propagate the malware to others.
- The vulnerability exploited by the researchers was in the Zigbee protocol employed by Philips Hue bulbs for communication, allowing them to retrieve the encryption keys used for authenticating messages between the bulbs.

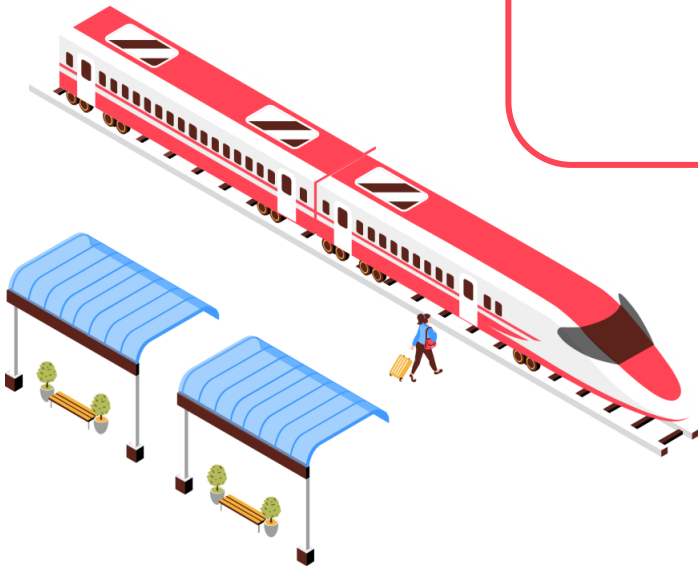


Threats and Attacks to ICS

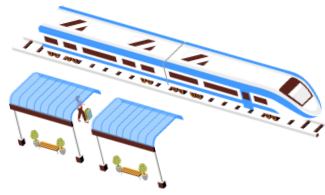


- The success of an attack on a computer system **depends on at least one vulnerability being exploited**; it can be technical, human or organizational.

Vulnerabilities of ICS

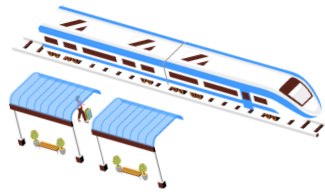


Vulnerability : the attack surface



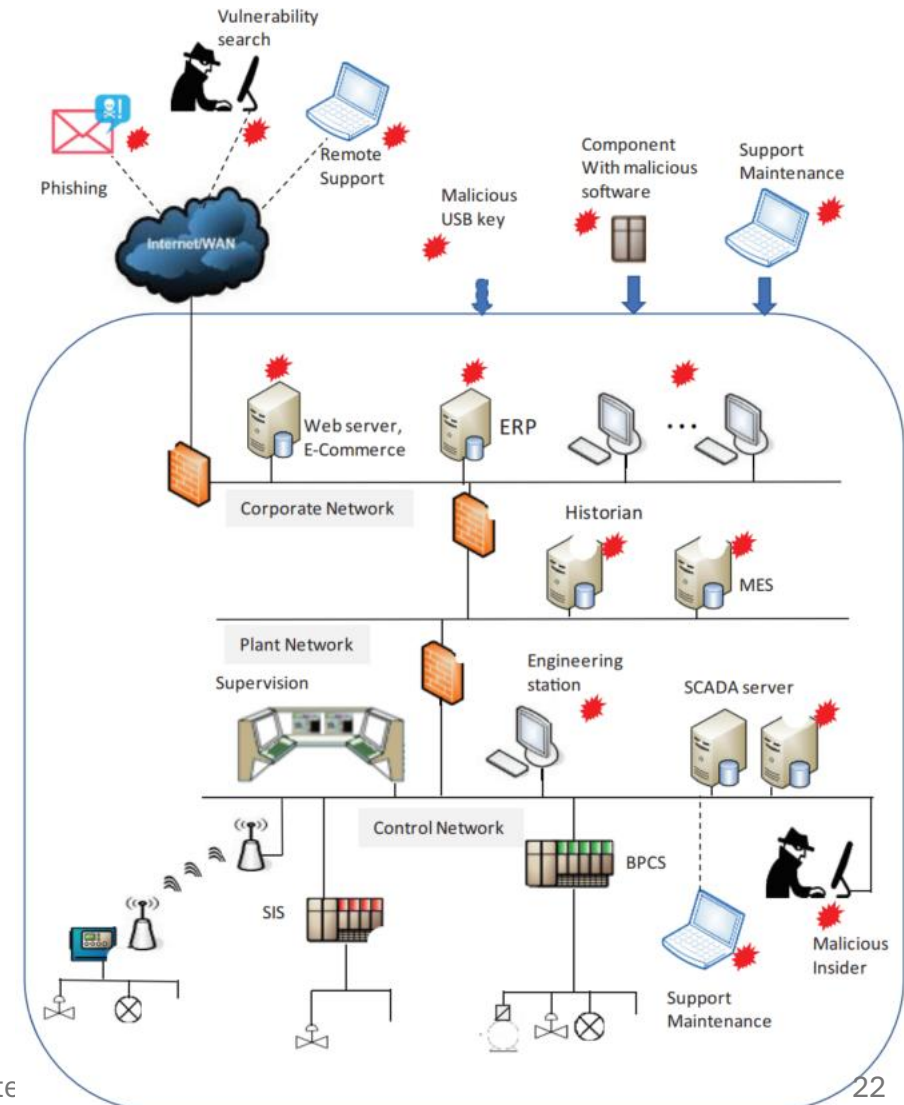
- A vulnerability refers to a **weakness or flaw** in a system, network, software, or hardware that can be exploited by attackers to compromise the confidentiality, integrity, or availability of information or resources.
- The attack surface of a system is defined as:
 - a description of all the points through which an attacker can enter;
 - the list of security measures;
 - the list of targets to be targeted.

Vulnerability : the attack surface

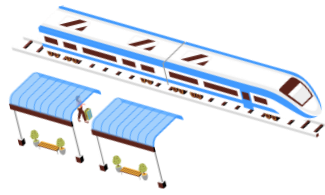


The entry points of an ICS are as follows:

- Poorly configured firewalls between the IT and OT network;
- demilitarized zone (DMZ) servers can be accessed from the external network or IT to introduce malware and can be used as relays;
- All workstations outside the OT network that are connected to it via a VPN (or without any particular protection);
- USB keys and other removable memory devices;
- Mobile computers or workstations connected by Wi-Fi that can be corrupted, when they are outside the OT network;

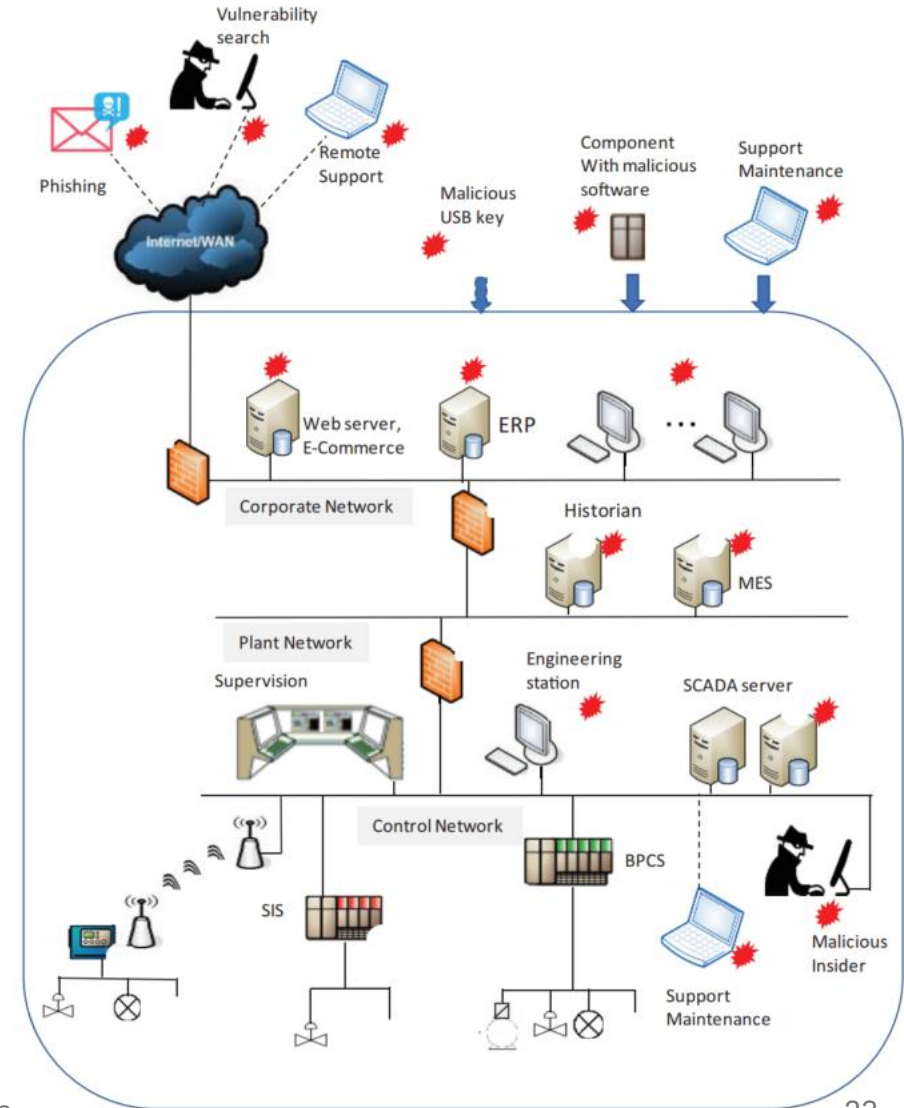


Vulnerability : the attack surface

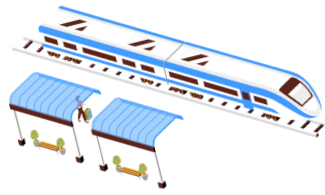


The entry points of an ICS are as follows:

- workstations in the OT network that can access the Internet or an external network, and can be corrupted by malware;
- the workstations in the OT network receiving emails;
- PLCs and other devices that connect to insufficiently secure update sites;
- workstations, equipment and software from untrustworthy suppliers;
- equipment with security breaches due to faulty design or implementation;
- unsecured physical access points.

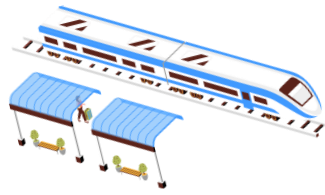


Vulnerability : Analysis

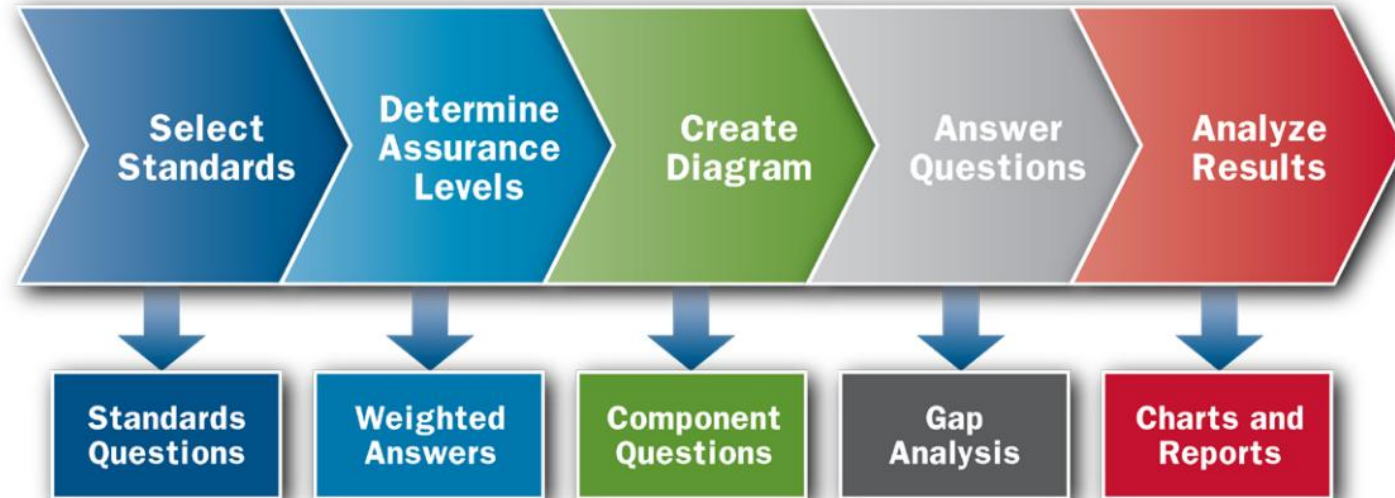


- Analysis of system vulnerabilities is an important step in the security process.
- Remember that A vulnerability is not just the presence of unpatched software designed to correct published vulnerabilities, but also the use of unnecessary services and applications that cannot be determined by simply scanning for the presence (or absence) of software.
- Two types of approach exist:
 - the first is based on an audit-type analysis, using a checklist, which makes it possible to go beyond technical vulnerabilities;
 - the second is based on software that automatically detects the various devices' vulnerabilities.

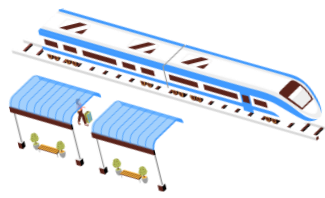
Vulnerability : CSET analysis



- One widely used tool to assess vulnerabilities and security posture in ICS/OT environments is the **Cyber Security Evaluation Tool (CSET)**.
- CSET is developed and maintained by the **Cybersecurity and Infrastructure Security Agency (CISA)** in collaboration with Idaho National Laboratory.
- It provides a **systematic, step-by-step approach** to evaluate an organisation's ICS and IT network security practices against multiple industry and government standards (including NIST SP 800-82 and ISA/IEC 62443).



Vulnerability : CSET analysis



West Creek Assessment.cset

CSET

Home Information Standards SAL Diagram Questions Analysis Reports

Categories

Selected Standards: Universal Questions

Security Assurance Level: Moderate

Filtering: Questions

- ✓ Access Control
- ✓ Account Management
- ✓ Audit and Accountability
- ✓ Communication Protection
- ✓ Configuration Management
- ✓ Continuity
- ✓ Environmental Security
- ✓ Incident Response
- ✓ Info Protection
- ✓ Information and Document Management
- ✓ Maintenance
- ✓ Monitoring & Malware
- ✓ Organizational
- ✓ Personnel
- ✓ Physical Security
- ✓ Plans
- ✓ Policies
- ✓ Policies & Procedures Governance
- ✓ Portable/Mobile/Wireless
- ✓ Procedures
- ✓ Remote Access Control
- ✓ Risk Management and Assessment
- ✓ System and Services Acquisition
- ✓ System Integrity
- ✓ System Protection
- ✓ Training

Component Defaults

Access Control

Access Agreements: Do you have any access agreements (formal or informal) for third party access to your system? Access agreements include nondisclosure agreements, acceptable use agreements, rules of behavior, operational or service level agreements and conflict-of-interest agreements.

1 Are appropriate agreements finalized before access is granted, including for third parties and contractors?

2 Are access agreements periodically reviewed and updated?

3 Are formal contractual and confidentiality agreements established for the exchange of information and software between the organization and external parties?

Access Enforcement

4 Does the system enforce assigned authorizations for controlling electronic access to the system?

Actions w/o ID/Auth: (e.g. Auto login or shared accounts)

5 Are specific user actions that can be performed on the system without identification or authentication identified and documented?

6 Are actions to be performed without identification and

1-Access Control

Details Universal

Info Supplemental

Title

2.3.6

Category

Personnel Security

SAL Level Low

Standard Specific Requirement

The organization completes appropriate agreements for control system access before access is granted. This requirement applies to all parties, including third parties and contractors, who require access to the control system. The organization reviews and updates access agreements periodically.

Source Documents

Document Title

[Catalog of Control Systems Security: Recommendations for Standards Developers Ver. 2](#)

Help Documents

Document Title

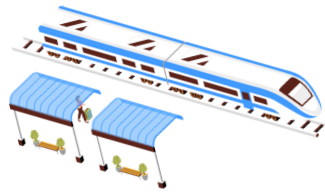
[NRC Cyber Security Programs for Nuclear Facilities](#)

[NRC Cyber Security Programs for Nuclear Facilities](#)

[Recommended Security Controls for Federal Information Systems and Organizations](#)

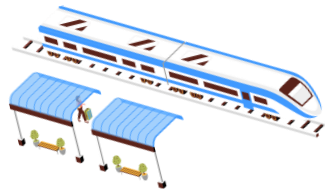
Diagram Help Documents Analysis

Vulnerability : tools



- Vulnerability analysis based on a checklist can be complemented with an analysis of the existing installation by software tools whose objective is to find **effective vulnerabilities**.
- Two approaches exist:
 - the first consists of consulting a **database of identified vulnerabilities**, using the hardware and software inventory (type and version number);
 - the second is to use **penetration test tools** to identify vulnerabilities in the installation.
- This second approach should of course be used with caution with an operational installation, given the disruption it may produce.

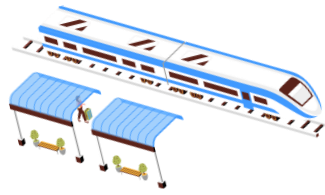
Vulnerability : tools



Databases and information sources

- **Standards and generic vulnerability lists**
 - ISO/IEC 27005 and **NIST SP 800-53 Revision 5** provide standard catalogues of security controls and generic vulnerabilities for information systems.
- **CERTs and vulnerability databases**
 - National and sectoral CERTs publish alerts and advisories on vulnerabilities affecting hardware, software and OT products.
 - Public databases such as the NVD (National Vulnerability Database) aggregate CVE records and severity scores.
- **ICS/OT-specific sources**
 - The **CISA ICS** portal (formerly ICS-CERT) provides advisories, alerts and recommended mitigations for industrial control systems and OT products.
 - These sources help operators track vulnerabilities that affect their specific PLCs, HMIs, SCADA software and network devices.

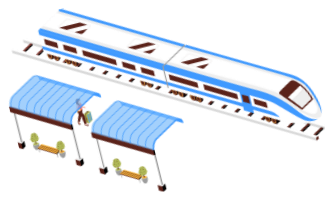
Vulnerability : tools



Penetration testing

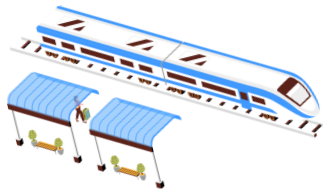
- Penetration testing is a common practice of security professionals to find system vulnerabilities before attackers do.
- They provide a real view of actual technical vulnerabilities, and are therefore a very useful complement to audit-based vulnerability analyses, even though they focus on a subset of the vulnerabilities in an installation.

Vulnerability : tools



- **Penetration testing**
- Several commercial and open-source tools exist to perform penetration tests. Let us quote, for example:
- OpenVAS, Nessus' open source fork, is a set of tools that provides a complete and powerful vulnerability management solution;
- **Kali Linux** is a Linux distribution dedicated to penetration testing. It includes many tools including OpenVAS, nmap, Metasploit;
- Linux-soft-exploit-suggester and Windows-Exploit-Suggester are more specific tools for analyzing a workstation's software vulnerability.

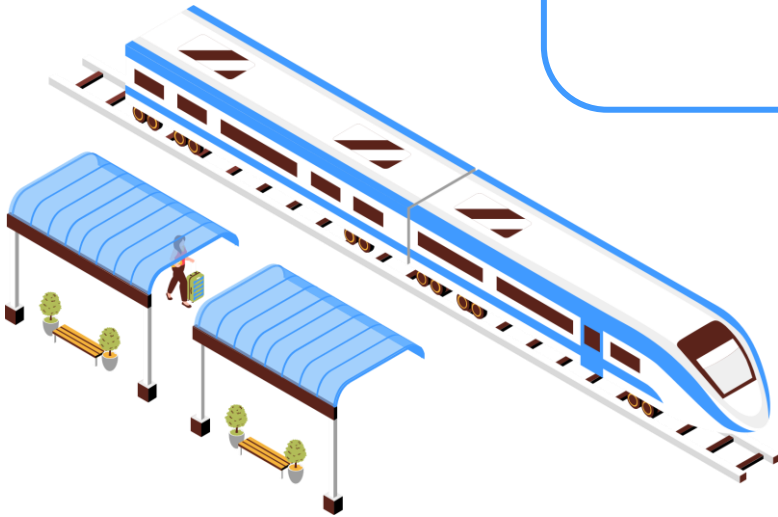
Vulnerability : tools



- Search engines
- Shodan

Remember: **vulnerability analysis** (including scanning, open-source intelligence and penetration testing) is **only one step** in a broader **risk assessment** process; it must be combined with asset criticality, threat likelihood and business impact.

Cybersecurity assessments





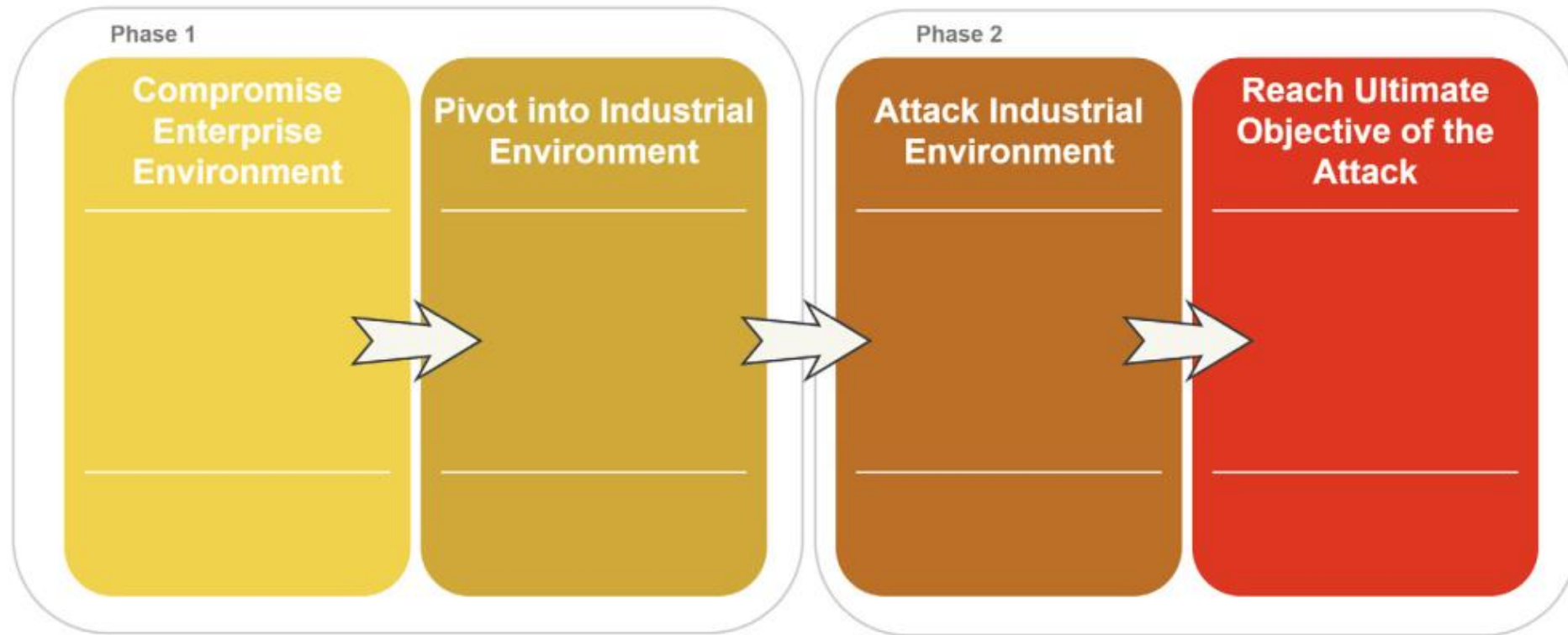
Types of cybersecurity assessments

- A cybersecurity assessment is a **systematic exercise** that is used to test your current security controls and evaluate how they stack up against known vulnerabilities in a controlled and methodical way.
- Different types of (cyber)security assessments can be used to verify different parts of the security posture and validate the overall cybersecurity program.
- Some common cybersecurity assessment types:
 - **Risk assessments**
 - Red team exercises
 - Blue team exercises
 - Penetration testing



Risk assessment

Remember : most ICS networks are not directly connected to the internet



This scenario differs from a regular IT attack where the objective is achieved by completing stage 1 activities or is part of stage 1 activities.



Risk assessment

Let's take an example :

*A spear-phishing campaign targets the business users of VictimCorp Inc. to try to have them **click on a malicious link** that results in their PC being infected with a **remote access trojan** (a backdoor malware).*

*Pivoting through the infected business system, the **adversary scans** the enterprise network for ICS workstations that could provide access to the ICS network. By exploiting a discovered vulnerability on an ICS workstation, the attacker gains access to the ICS network and starts attacking the turbine control to have it spin out of control and fail.*

Can you define stage 1 and stage 2 attacks ?



Risk assessment

*A spear-phishing campaign targets the business users of VictimCorp Inc. to try to have them **click on a malicious link** that results in their PC being infected with a **remote access trojan** (a backdoor malware).*

*Pivoting through the infected business system, the **adversary scans** the enterprise network for ICS workstations that could provide access to the ICS network. By exploiting a discovered vulnerability on an ICS workstation, the attacker gains access to the ICS network and starts attacking the turbine control to have it spin out of control and fail.*

Stage 1 attack is a spear-phishing campaign where the **objective of stage 1** is to gain access into VictimCorp's business network and pivot into the ICS network. Once inside the ICS network, stage 2 of the ICS attack is carried out, with the **stage 2 attack** targeting the centrifuge controls.

The objective of stage 2 and the entire ICS attack is to get the centrifuge to fail



Risk assessment

- The business dictionary defines risk assessment as:

"The identification, evaluation, and estimation of the levels of risks involved in a situation, their comparison against benchmarks or standards, and determination of an acceptable level of risk".

- The book "Hacking exposed – Industrial Control Systems" defines risk as follows :

*Risk is the likelihood that a **threat source** will cause a threat event, by means of a **threat vector**, due to a **potential vulnerability** in a target, and what the resulting consequence and impact will be*



Risk assessment

- Let's look closer at this description:
- A *threat source* is the initiator of the exploit, the attacker or threat actor.
- A *threat event* is an act of exploiting a vulnerability, or an attack on the system under consideration (SUC).
- A *threat vector* is the avenue of attack or the delivery method of the exploit, such as using an infected thumb drive or using a phishing email to deliver a malicious payload.
- A *vulnerability* is a flaw in the SUC.
- *Likelihood* is the chance of the vulnerability found becoming a threat event.
- A *target* is the SUC.
- A *consequence* is the direct result of a successful threat event, such as the crashing of a service or the installation of a malicious program.
- The *impact* is the effect on the operations, image, or financial welfare of the victim company



Risk assessment

- The result of a risk assessment is a **risk score** for a discovered vulnerability.
- The score takes into consideration all the factors that define risk with the following equation:

$$risk = \frac{severity + (criticality * 2) + (likelihood * 2) + (impact * 2)}{4}$$



Risk assessment

$$risk = \frac{severity + (criticality * 2) + (likelihood * 2) + (impact * 2)}{4}$$

- **Severity** is a number ranging from 0 to 10, given to the vulnerability by a service such as the Common Vulnerability Scoring System (CVSS).
- **Criticality** is a number between 1 and 5 that reflects the importance of the SUC to the overall process.
- **Likelihood** is a number between 1 and 5 reflecting the chances of the vulnerability becoming a successful threat event.
- **Impact** is a number between 1 and 5 that reflects the financial impact to the company in the case of a compromise or failure of this system, the associated damage to the image of the company, the potential impact on the environment, and the associated risk to employee and public health and safety.



Risk assessment: process

Identifies potential **targets**

Asset Identification and
System Characterization

Identifies potential
vulnerabilities and **threat vectors/**
sources/events, and estimates
likelihood and **consequence**

Vulnerability
Identification and Threat
Modeling

Calculates the potential **impact**

Risk Calculation and
Mitigation



Risk assessment: process

Asset Identification and System Characterization:

- This step involves finding all the assets of the system under consideration and assessing their **criticality** and the asset value, used for the **impact** scoring calculation.
- The outcome of this step is a **list of potential targets**.

Vulnerability Identification and Threat Modeling:

- This step involves discovering any potential vulnerabilities within the discovered assets and their associated CVSS score for severity calculation
- Followed by threat-modeling techniques to add information on threat vectors, threat events, and threat sources.
- Then assessing the likelihood and consequence of a compromise
- The outcome of this step will be a list of matrix with potential risk scenarios, made relevant and actionable for the system under consideration.



Risk assessment: process

The third **step** is **Risk Calculation and Mitigation**:

- This step involves assessing the total impact of a threat event for each discovered target's vulnerability
- Combining all the discovered information, this step calculates the risk score
- The outcome of this step will be an **actionable risk scoring per vulnerability** that helps strategize remediation efforts